Continuous Monitoring and Digital Surveillance

Mukombo

Content

- Monitoring software.
- Digital Forensic acquisition.
- Social engineering

Introduction

- Continuous monitoring and digital surveillance form the backbone of modern fraud detection systems, combining **real-time threat detection** with **forensic investigation capabilities**.
- It is critical for identifying both **external attacks** and **internal fraud schemes**.

Objectives:

- Detect fraud attempts in real-time
- Maintain audit trails for investigations
- Deter fraudulent activities through visible monitoring
- Support regulatory compliance

Monitoring Software for Fraud Detection

A. Types of Monitoring Solutions

1. Security Information and Event Management (SIEM) Systems

- **Function:** Aggregates and analyzes log data from multiple sources
- **Fraud Detection Capabilities:**
  i. Correlation of login attempts with transaction activities
  ii. Detection of privilege escalation patterns
  iii. Identification of data exfiltration attempts

Example:

i. A SIEM detects an employee accessing sensitive financial records at 3 AM from a foreign IP, followed by unusual database exports

2. User and Entity Behavior Analytics (UEBA)

- **Function:** Machine learning-based profiling of normal user behavior
- **Fraud Indicators:**
  i. Abnormal data access patterns
  ii. Unusual transaction timing/amounts
  iii. Violation of segregation of duties

Example:

i. A bank's UEBA flags an accounts payable clerk suddenly accessing executive compensation records.

3. Database Activity Monitoring (DAM)

- **Function:** Tracks all database queries and modifications
- **Fraud Prevention Features:**
  i. Alert on unauthorized schema changes
  ii. Detect SQL injection attempts
  iii. Identify suspicious data exports
- **Example:**
  i. DAM logs show a user running SELECT * FROM customers followed by DELETE FROM audit_log - clear evidence of fraud cover-up.

4. Endpoint Detection and Response (EDR)

- **Function:** Monitors workstation activities
- **Key Monitoring Points:**
  i. USB device usage
  ii. Print job monitoring
  iii. Clipboard activities for sensitive data

Example:

i. EDR detects an employee copying customer credit card numbers to a text file.

Implementation Considerations

Factor	Requirements
Deployment Model	Cloud/On-prem/Hybrid
Data Sources	Network logs, DB logs, App logs, Cloud services
Alert Tuning	Threshold configuration to reduce false positives
Integration	Fraud management systems, Case management tools
Retention Period	Minimum 1 year for compliance

Digital Forensic Acquisition

- Digital Forensic Acquisition is the process of creating a forensically sound, bit-for-bit copy (an "image") of digital evidence from a source (e.g., hard drive, server, phone, cloud data) in a manner that preserves its integrity and makes it admissible in legal proceedings.
- In fraud cases, this evidence is the foundation for identifying how the fraud was committed, who was responsible, and for supporting recovery actions.

Key Principles (The "Pillars" of Forensic Soundness)

- For evidence to be admissible in court (whether criminal or internal disciplinary), the acquisition process must adhere to these principles:

i. **Minimise Data Alteration:** This is achieved using **write-blocking hardware** (a physical device) or **software write-blockers** that prevent any data from being written to the source drive.

ii. **Document the Chain of Custody:** A meticulous, unbroken record of everyone who handled the evidence, when, why, and what they did with it. Any gap can render evidence inadmissible.

iii. **Preserve Original Evidence:** The original source media is never used for analysis. All investigation is performed on the forensic image copy.

iv. **Document All Actions:** Every step taken by the examiner must be recorded, repeatable, and verifiable by a third party.

The Acquisition Process in a Fraud Investigation

Phase 1: Preparation & Readiness (Proactive Prevention)

- **Policy Development:** Have clear policies for example stating that company-owned devices and systems are subject to monitoring and investigation. This sets the expectation and legal basis for acquisition.
- **Toolkit Ready:** Maintain and regularly update forensic hardware (write-blockers, storage drives) and software (FTK Imager, X-Ways, EnCase, Autopsy).
- **Trained Personnel:** Have staff trained in forensic acquisition procedures or a retainer with a reputable digital forensics firm.
- **Secure Storage:** Ensure there is a secure, locked environment for storing evidence.

Phase 2: Identification & Collection (Reactive Detection)

- **Identify the Scope:** Based on the fraud allegation, identify potential sources of evidence:
  i. **Workstations/Laptops** of suspects and involved parties.
  ii. **File Servers** and **Email Servers** (e.g., for manipulated documents or fraudulent communication).
  iii. **Database Servers** (e.g., for altered transaction records, fake vendor entries).
  iv. **Network Logs** (Firewalls, VPNs, Proxies) for access patterns.
  v. **Cloud Storage** (Google Drive, OneDrive, Dropbox) – requires specialized cloud acquisition tools.
  vi. **Mobile Devices** (SMS, call logs, messaging apps, photos).
  vii. **Removable Media** (USB drives, external HDDs).
- **Secure the Scene:** Physically secure devices to prevent tampering or destruction. For servers, coordinate with IT to isolate them logically (e.g., disable accounts) without shutting them down if volatile memory (RAM) is needed

Phase 3: Acquisition - Key Methods

- **Static Acquisition (Most Common):**
  i. Acquiring data from a powered-off device.
  ii. The device is connected to a forensic workstation via a write-blocker.
  iii. A forensic image is created.
  iv. This practice is best for preserving long-term data on hard drives and SSDs.
- **Live Acquisition:**
  i. Acquiring data from a powered-on system.
  ii. **Critical for capturing volatile data** that disappears upon shutdown:
    a) Running processes (e.g. malicious software).
    b) Open network connections (data exfiltration).
    c) RAM contents (encryption keys, unsaved documents, chat conversations).
  iii. **Risks:** The act of acquisition changes the system's state slightly, but this is well-documented and accepted practice for capturing crucial evidence.
- **Cloud & Remote Acquisition:**
  i. Involves using APIs from providers (Microsoft 365, Google Workspace) to preserve and export data in a forensically sound manner.
  ii. Often requires third-party tools designed for cloud environments.
- **Network Acquisition:**
  i. Capturing network traffic (packets) in real-time.
  ii. Useful for detecting ongoing data theft or fraudulent communication.

Phase 4: Verification

- After creating a forensic image, **cryptographic hash values** (MD5, SHA-1, SHA-256) are generated for both the original source and the image.
- If the hashes match, it proves the image is an exact, unaltered copy. This must be done to uphold evidence integrity.

III. How Acquisition Directly Supports Fraud Detection & Prevention

- **Uncovering the "How".** Forensic images allow examiners to:
  i. Recover **deleted files** (fraudulent invoices, altered spreadsheets).
  ii. Analyze **file metadata** (creation dates, last modified dates, author information) to prove a document was back-dated.
  iii. Examine **internet history** and **search queries** to show intent or research into fraudulent methods.
  iv. Extract **email and chat logs** to prove collusion or authorization of fraudulent acts.
  v. Analyze **application logs** and **database transactions** to identify unauthorized changes.
- **Identifying the "Who".** Images preserve user activity artifacts:
  i. **User account** used to perform actions.
  ii. **Login/Logoff times** from system logs.
  iii. **File ownership** and access permissions.
- **Quantifying the "Impact":** Allows for a complete audit of data to determine the full scope of the financial loss.
- **Deterrence (Prevention):** The mere existence of a capable digital forensic process acts as a powerful deterrent against internal fraud. Employees are less likely to commit fraud if they know their digital actions can be thoroughly traced.

Summary of the Forensic Process Flow

- **Identification:** Locate relevant systems/devices
- **Preservation:** Secure evidence without alteration
- **Collection:** Acquire data using forensically sound methods
- **Examination:** Analyse collected evidence
- **Reporting:** Document findings for legal proceedings

Social Engineering

Social Engineering

- Social engineering (SE) is the psychological manipulation of people into performing actions or divulging confidential information.
- Unlike technical attacks that exploit software vulnerabilities, SE exploits the human vulnerability.
- In the context of fraud detection, the goal is to continuously monitor digital channels to detect SE attacks in progress and to survey user behavior for signs of successful manipulation.
- This shifts the focus from purely preventative measures (like training) to active detection and response.

The Imperative for Continuous Monitoring of SE

- **Volume & Sophistication:** SE attacks, especially phishing, are high-volume and increasingly sophisticated (e.g., deepfake audio for "vishing").
- **Bypass Technical Controls:** A well-crafted spear-phishing email may contain no malicious links or attachments, bypassing traditional email security gateways. It relies solely on tricking the user.
- **The “Last Mile” of Fraud:** SE is often the initial access vector for major fraud schemes (Business Email Compromise, wire fraud, data theft). Detecting it early is the most effective way to prevent significant financial loss.
- **Insider Threat Identification:** Continuous monitoring can identify employees who are being actively cultivated or manipulated by external actors, turning them into unwitting insiders.

Research Questions

1. How do social engineering attacks orchestrate multi-channel campaigns (e.g., a LinkedIn recon mission followed by a spear-phishing email and a vishing call), and what is the most effective method for correlating these events in real-time across separate monitoring systems (Email, SWG, UEBA, VoIP logs)?
2. To what extent does activity on one channel (e.g., a user visiting a credential-harvesting site detected by a SWG) predict a subsequent malicious action on another channel (e.g., an anomalous cloud login detected by a CASB or UEBA)? Can a probabilistic model be built to forecast attack progression?
3. What is the efficacy of using a centralized security data lake (aggregating logs from email, web, endpoint, cloud, and network) versus best-of-breed individual channel monitoring tools for detecting sophisticated, multi-vector social engineering attacks?
4. What are the comparative false positive and false negative rates of machine learning-based Advanced Email Security systems versus traditional signature-based systems in detecting Business Email Compromise (BEC) and spear-phishing attempts that lack malicious payloads?
5. How effective are User and Entity Behavior Analytics (UEBA) platforms at accurately establishing a behavioral baseline for remote and hybrid workers, whose patterns may be inherently more variable, and does this variability lead to increased alert fatigue for SOC analysts?
6. What metrics are most appropriate for measuring the Return on Investment (ROI) of Deception Technology in a social engineering context (e.g., number of early-stage compromises detected, estimated losses prevented) compared to other monitoring technologies?.
7. How does the implementation of continuous digital surveillance for SE detection impact employee perception of organizational trust and privacy, and what communication and policy strategies most effectively mitigate negative cultural repercussions?

Integrating SE Monitoring into SOC Workflows

Continuous monitoring requires a process managed by the Security Operations Center (SOC).

- **Data Collection:** Aggregate logs from all relevant sources (email, web proxies, endpoints, cloud apps, network) into a central platform like a SIEM.
- **Alerting & Correlation:** Use the SIEM and analytics tools (UEBA) to correlate events.
- **Triage & Investigation:** Analysts investigate alerts. They examine the original email, user's subsequent actions, and endpoint status to determine if it's a true positive.
- **Response & Mitigation:** If confirmed, incident response is triggered:
  a) **Immediate:** Force password reset, quarantine the endpoint, block malicious domains/IPs.
  b) **Forensic:** Begin digital forensic acquisition to determine the scope of the breach.
  c)**Communication:** Inform leadership, legal, and PR as per the incident response plan.
- **Feedback Loop:** Use findings from incidents to:
  a) **Update Detection Rules:** Tune alerts to reduce false positives and catch new tactics.
  b) **Target Training:** Provide mandatory, immediate security training to the user who fell for the attack and others in their department.

Critical Legal, Ethical, and Privacy Considerations

- **Transparency:** Employees must be informed that company systems and communications are monitored for security and fraud prevention purposes. (Is this case in our country?)
- **Proportionality:** Monitoring should be focused on detecting malicious activity, not on personal employee surveillance. The scope should be clearly defined and limited to corporate assets. Avoid being "**Big Brother".**
- **Compliance:** Ensure practices comply with regulations which govern the collection and processing of employee data.
- **Culture of Trust:** Position monitoring as a tool to protect employees and the company from external threats, not as a tool to spy on them. This is crucial for maintaining morale and encouraging reporting of suspicious activity